

Vulnerability Prioritization & Triage System

Temporal Evaluation of Vulnerability Scoring and Exploitation Prediction Under Feature-Timing Constraints

Shams Tabrez Ahmed (Lead Author) Abaan Mhaiker (Co-author)
Om Shelke (Co-author) Ayush Singasane (Co-author) Lakshya Walurkar (Co-author)
Department of Computer Engineering, Vidyalankar Institute of Technology (VIT), Mumbai

October 2026

Abstract

Vulnerability management requires analysts to distinguish severe vulnerabilities from those that are more likely to be exploited, while accounting for the assets affected. Machine-learning evaluations in this area can be misleading when feature values are enriched after the prediction time or when retrospective threat-intelligence snapshots are treated as if they had been available at disclosure. This paper presents the Vulnerability Prioritization & Triage System (VTS), a research prototype and reproducible data pipeline for vulnerability analysis. Using an NVD-derived dataset of 366,547 canonical CVE records frozen on July 26, 2026, we evaluate (i) CVSS v3.1 score regression, (ii) KEV-catalog membership prediction without EPSS under a temporal partition using archived metadata, and (iii) a retrospective EPSS sensitivity comparison between the no-EPSS baseline and a later static EPSS snapshot. Preprocessing is conducted under a strict inductive protocol: all transformations (TF-IDF vocabulary and categorical encodings) are fitted exclusively on training data during hyperparameter selection and refitted on train-plus-validation data prior to test evaluation, preventing test-partition leakage. In the CVSS regression experiment, XGBoost achieves a mean absolute error (MAE) of 0.9721, compared with 1.0918 for a Ridge baseline, a relative reduction of approximately 11.0% on the held-out partition. In the KEV-membership prediction experiment without EPSS under a temporal split (EXP-B2), the model obtains an average precision (AP) of 0.02718, ROC-AUC of 0.82874, and Precision@500 of 7.2% (36 hits out of 294 KEV positives in 91,242 test CVEs; 0.3222% base rate). In contrast, adding a static EPSS snapshot dated July 16, 2026 (EXP-B1) increases average precision (AP) to 0.33578 and Precision@500 to 26.8% (134 hits), illustrating a retrospective sensitivity comparison consistent with substantial look-ahead information effects. Neither the ~11% reduction in CVSS regression error nor the retrospective EPSS score comparison demonstrates operational security effectiveness: descriptions and metadata originate from cumulative post-analysis snapshots rather than verified zero-hour states, and an exploratory ranking simulation (EXP-C1) exposes an exact boundary-saturation defect at CVSS 10.0 that distorts top- k triage queues. The results support rigorous feature-timing qualification and transparent evaluation rather than claims of operational defense capability.

1. Introduction

Vulnerability management teams face an acute prioritization challenge: the volume of published vulnerabilities continues to grow, while human analytical bandwidth and remediation capacity remain constrained. Technical severity, exploitation likelihood, and asset criticality represent related but fundamentally distinct dimensions of cyber risk. A high severity score does not establish that a vulnerability is being exploited in the wild, and an exploitation likelihood estimate does not by itself express the business or mission impact on a specific organizational asset.

The Common Vulnerability Scoring System (CVSS) provides standardized technical severity information. The Exploit Prediction Scoring System (EPSS) estimates the probability that a vulnerability will experience exploitation activity in the wild over a forthcoming 30-day window. The Cybersecurity and Infrastructure Security Agency’s Known Exploited Vulnerabilities (KEV) catalog records vulnerabilities with confirmed in-the-wild exploitation. These sources answer distinct operational questions and should not be treated as interchangeable risk labels [1]–[3].

Machine-learning evaluations of vulnerability prioritization are particularly vulnerable to feature-timing fallacies. A model evaluated on historical vulnerabilities may ingest threat-intelligence scores or enriched vulnerability metadata that became available only months or years after disclosure. Such an evaluation measures retrospective pattern

matching rather than the prospective predictive utility available to an analyst at triage time. This distinction remains critical even when training and testing sets are partitioned chronologically.

This paper presents the **Vulnerability Prioritization & Triage System (VTS)**, a research prototype for reproducible vulnerability data processing, model evaluation, and decision-support analysis. The paper makes three empirical contributions:

1. It reports a temporally partitioned CVSS v3.1 regression experiment comparing XGBoost against a regularized linear (Ridge) baseline under leakage-safe inductive preprocessing.
2. It reports a temporally held-out KEV-membership classification experiment using archived disclosure metadata without EPSS under severe class imbalance (0.3222% positive base rate).
3. It conducts a retrospective sensitivity comparison comparing the no-EPSS classifier against an otherwise identical model family supplied with a later static EPSS snapshot, observing performance shifts consistent with substantial post-disclosure threat telemetry and model retuning.

Because the underlying vulnerability records originate from a cumulative NVD archive snapshot, the temporal split should be interpreted as a temporal partition of post-analysis records, not as a verified prospective replay of zero-hour disclosure data. Furthermore, the paper documents an exploratory multi-factor ranking simulation whose nonlinear formula exhibited an exact boundary-saturation defect; this simulation is analyzed as an exploratory case study rather than as a validated operational ranking policy.

2. Background and Related Work

2.1 Vulnerability severity and exploitation signals

CVSS communicates technical vulnerability characteristics through a standardized framework. While essential for establishing severity, CVSS base scores do not model whether exploitation will occur in a specified operational time-frame. NIST has published comprehensive empirical analyses of the CVSS base-score equation and its measurement properties [1].

EPSS addresses a different task: estimating the probability of exploitation activity in the wild over the next 30 days. EPSS estimates are generated dynamically and incorporate daily threat-intelligence observations [2], [3]. Consequently, an EPSS score retrieved from a later static snapshot cannot be treated as a feature that was available at an earlier CVE disclosure date.

CISA’s KEV catalog identifies vulnerabilities with confirmed active exploitation in the wild, serving as a binding remediation directive for federal agencies and a widely adopted benchmark for prioritization [4]. KEV membership is an observational catalog label, not an exhaustive record of all vulnerabilities that have ever been or will ever be exploited. In this study, the target label denotes presence in the KEV catalog as of the dataset freeze date.

2.2 Data-driven vulnerability assessment

Surveys of data-driven vulnerability assessment emphasize that chronological partitioning is necessary but not sufficient to ensure methodological validity [5]. If feature extraction draws upon post-disclosure enrichments—such as refined vendor descriptions, retrospective CWE mappings, or updated CPE configurations—the evaluation exhibits temporal metadata leakage even across strict publication-year splits.

2.3 Model interpretability

SHAP (SHapley Additive exPlanations) provides a game-theoretic approach to feature attribution in tree-based ensembles [6]. In this study, SHAP values are examined strictly as post-hoc descriptions of model associations, not as causal drivers of exploitation.

3. System Overview

VTS is an academic research prototype combining vulnerability data ingestion, canonicalization, inductive feature extraction, model evaluation, and an interactive decision-support interface. The system processes a frozen corpus of 366,547 canonical CVE records spanning 1988–2026, alongside related CWE, CPE, EPSS, KEV, and vendor data feeds.

Different experiments in VTS evaluate specific subpopulations: EXP-A1 evaluates the 227,694 records with official CVSS v3.1 scores; EXP-B1 and EXP-B2 evaluate the complete canonical population across identical temporal partitions (203,652 training, 71,653 validation, and 91,242 test records); and EXP-C1 analyzes the intersected multi-source population.

VTS is designed for human triage assistance and research exploration. It is not an automated blocking tool, has not been tested against operational incident-response feeds, and does not claim enterprise breach-reduction capabilities.

4. Data and Methodology

4.1 Data snapshot and label semantics

The raw NVD feeds were acquired in a single cumulative snapshot on July 26, 2026. The ingestion pipeline retains the official NVD publication date and last-modified timestamp. However, it does not reconstruct historical versions of descriptions, CWE tags, or CPE applicability statements as they existed on the disclosure date.

The KEV exploitation label denotes whether a CVE was cataloged by CISA as of the July 26, 2026 freeze date. Unlisted CVEs cannot be assumed to be permanently unexploited, and vulnerabilities published later in the 2025–2026 test window have had less cumulative calendar exposure to exploitation discovery.

4.2 Temporal partition and inductive preprocessing protocol

Records are partitioned chronologically by official publication year:

Partition	Publication years	Canonical records	CVSS v3.1 subset (EXP-A1)
Training	2002–2022	203,652	78,172
Validation	2023–2024	71,653	67,918
Test	2025–2026	91,242	81,604

To prevent transductive data leakage, preprocessing follows a strict two-stage inductive protocol: 1. **Model Selection & Tuning Stage:** All feature transformers—including the 500-term TF-IDF vectorizer (sublinear term frequency, English stop words, unigrams and bigrams), the top-20 semantic CWE category frequency rankings, and CPE categorical aggregations—are fitted solely on the training partition (≤ 2022). The validation partition (2023–2024) is transformed using these training-fitted parameters to guide hyperparameter selection. 2. **Final Evaluation Stage:** Once hyperparameters are frozen, the preprocessor is refitted from scratch on the combined training and validation partitions (≤ 2024) to maximize historical representation. It is then applied unchanged to transform the held-out test partition (≥ 2025).

This protocol guarantees that no test-split vocabulary, future CWE distributions, or document frequencies influence model training or selection. However, because the underlying text and metadata originate from the cumulative July 26, 2026 snapshot, this remains a temporally held-out evaluation on archived metadata rather than a verified zero-hour prospective evaluation.

4.3 EXP-A1: CVSS v3.1 score regression

EXP-A1 evaluates whether text descriptions and high-level architectural metadata can predict numeric CVSS v3.1 base scores ($[0.0, 10.0]$) before formal scoring by an analyst. The feature set contains 531 features: 500 TF-IDF n-grams, 20 CWE indicators, six CPE features, and publication-month/flag indicators. CVSS vector strings, EPSS, KEV status, and post-publication fields are excluded.

The test set comprises 81,604 CVEs published in 2025–2026. XGBoost Regressor is evaluated against a Ridge regression baseline. Performance is measured using mean absolute error (MAE), root mean squared error (RMSE), and coefficient of determination (R^2).

4.4 EXP-B2: KEV-membership classification without EPSS under a temporal split

EXP-B2 evaluates KEV-membership prediction without EPSS under a temporal split using archived disclosure metadata. While designed to emulate an initial triage setting where external threat scores are not yet available,

historical versions of NVD descriptions, CWE assignments, and CPE applicability statements cannot be reconstructed from the snapshot; the experiment thus evaluates held-out records rather than a verified prospective disclosure state. The model predicts KEV catalog inclusion by the freeze date using the 531-feature baseline, strictly excluding EPSS scores and percentiles. The test set comprises 91,242 CVEs, containing 294 KEV-positive records (prevalence: 0.3222%).

Because of extreme class imbalance, performance is reported using average precision (AP) (computed via `average_precision_score`), ROC-AUC, Precision@500, and Recall@500.

4.5 EXP-B1: Retrospective EPSS-snapshot sensitivity analysis

EXP-B1 evaluates the same model families and base feature set as EXP-B2, but appends two fields from a static EPSS snapshot downloaded on July 16, 2026: the numeric EPSS score and EPSS percentile.

Because hyperparameters were tuned independently on validation data for each experiment, model configurations differ between the two settings (e.g., Logistic Regression selected $C = 1.0$ in EXP-B2 versus $C = 10.0$ in EXP-B1, and XGBoost selected `scale_pos_weight=100`, `depth=6` in EXP-B2 versus `scale_pos_weight=20`, `depth=4` in EXP-B1). Because the EPSS snapshot date (July 16, 2026) postdates the disclosure of the 2025–2026 test CVEs, EXP-B1 serves strictly as a retrospective sensitivity analysis and explicit negative control rather than a prospective evaluation. Calling this comparison a sensitivity comparison rather than an isolated single-variable ablation clarifies that both feature inputs and selected hyperparameters vary between the two setups.

4.6 EXP-C1: Exploratory ranking simulation

EXP-C1 examines multi-criteria triage scoring over 227,694 intersected CVEs. Let $x_1 = \text{CVSS}/10 \in [0, 1]$, $x_2 = \text{EPSS} \in [0, 1]$, $x_3 = \text{is_kev} \in \{0, 1\}$, and $x_4 \in \{0.25, 0.50, 0.75, 1.00\}$ represent asset criticality tiers. The linear baseline and nonlinear complement-product surface formulas are:

$$S_{\text{linear}} = 0.25x_1 + 0.25x_2 + 0.25x_3 + 0.25x_4$$

$$S_{\text{nonlinear}} = x_4 [1 - (1 - x_1)^{1+\alpha x_3} (1 - x_2)^{1+\beta x_3}], \quad \alpha = 1.0, \beta = 1.5.$$

This experiment is retained strictly as an exploratory investigation of mathematical scoring properties, not as a recommended triage policy.

5. Results

5.1 EXP-A1: CVSS regression

Table 5.1 reports out-of-sample regression metrics on the 81,604 held-out test records under the inductive preprocessing protocol.

Table 5.1: EXP-A1 test partition regression performance (2025–2026).

Model	Hyperparameters	Test MAE	Test RMSE	Test R^2
Ridge baseline	$\alpha = 1.0$	1.0918	1.4051	0.3231
XGBoost	$\text{depth} = 8, n =$	0.9721	1.3046	0.4165
Regressor	$200, \eta = 0.05$			

XGBoost achieves an MAE of 0.9721, representing an approximate 10.96% relative error reduction over the Ridge baseline (1.0918) on this held-out test partition under inductive preprocessing. Because this evaluation reports performance on a single chronological test partition, these metrics describe observed out-of-sample accuracy on this specific split rather than establishing uniform stability across arbitrary disclosure intervals. We note that hyperparameter tuning on validation data selected $\alpha = 1.0$ for Ridge (compared with $\alpha = 10.0$ under the earlier transductive baseline), indicating that metric differences between baseline and corrected runs reflect joint effects of leakage removal and parameter re-tuning.

5.2 EXP-B2: KEV-membership prediction without EPSS under a temporal split

Table 5.2 reports classification performance on the 91,242 test CVEs using archived publication metadata alone.

Table 5.2: EXP-B2 test partition classification performance without EPSS.

Metric	Logistic Regression	XGBoost Classifier
Hyperparameters	$C = 1.0$ spw = 100, depth = 6, $n = 200$, $\eta = 0.05$	
Test records	91,242	91,242
KEV-positive records	294	294
Positive prevalence	0.3222%	0.3222%
Average precision (AP)	0.01737	0.02718
ROC-AUC	0.84969	0.82874
Precision@500	0.0300 (15/500)	0.0720 (36/500)
Recall@500	0.05102 (15/294)	0.12245 (36/294)
Random baseline AP	0.00322	0.00322

XGBoost achieves an average precision (AP) of 0.02718, which is approximately $8.4\times$ the random baseline prevalence (0.00322). At a fixed triage budget of 500 CVEs, XGBoost identifies 36 KEV-positive vulnerabilities (Precision@500 = 7.2%, Recall@500 = 12.25%).

During validation tuning under inductive preprocessing, XGBoost selected a higher class weighting (`scale_pos_weight=100`, compared with 20 previously), which expanded top-500 recall. The corrected run’s average precision decreased from 0.02884 to 0.02718 relative to the earlier transductive baseline. This difference may reflect multiple changes, including inductive preprocessing and hyperparameter re-selection; the experiment does not isolate the contribution of out-of-vocabulary terms.

5.3 EXP-B1 versus EXP-B2: retrospective EPSS sensitivity comparison

Table 5.3 presents the sensitivity comparison between the publication-metadata model (EXP-B2) and the retrospective snapshot model (EXP-B1) on the exact same test partition.

Table 5.3: Comparison between EXP-B2 (no EPSS) and EXP-B1 (retrospective EPSS snapshot).

Metric	EXP-B2: No EPSS	EXP-B1: Retrospective EPSS	Difference (Δ)
Average precision (AP)	0.02718	0.33578	+0.30860
ROC-AUC	0.82874	0.98295	+0.15421
Precision@500	0.0720	0.2680	+0.1960
True positives in top 500	36 / 500	134 / 500	+98
Recall@500	0.12245 (36/294)	0.45578 (134/294)	+0.33333

Providing the July 16, 2026 static EPSS snapshot increases average precision (AP) from 0.02718 to 0.33578—a 12.35-fold relative increase—while Precision@500 rises from 7.2% to 26.8% (capturing 134 of the 294 KEV vulnerabilities).

Because the test CVEs and partition boundaries are identical, this marked divergence provides a retrospective sensitivity comparison consistent with substantial look-ahead information effects. However, because hyperparameters were tuned independently on the validation partition for each experiment (e.g., XGBoost selected `scale_pos_weight=20`, `depth=4`, `n=100`, `lr=0.1` for EXP-B1 versus `scale_pos_weight=100`, `depth=6`, `n=200`, `lr=0.05` for EXP-B2, and Logistic Regression selected $C = 10.0$ versus $C = 1.0$), the metric differences cannot be attributed solely to threat-intelligence leakage in isolation; they reflect the joint impact of later EPSS data and model retuning. Nonetheless, the magnitude of the metric increase demonstrates that retrospective EPSS scores cannot serve as valid evidence of publication-time triage efficacy.

5.4 EXP-C1: exploratory saturation finding

In EXP-C1, the linear and nonlinear scoring functions were evaluated across four asset criticality tiers on 227,694 CVEs. Across all tiers, global rank correlation between the two formulas remained high (Spearman $\rho = 0.9962$, Kendall $\tau = 0.9356$). However, the top-100 Jaccard overlap was only 0.005 (0.5%), and the top-1000 Jaccard overlap was 0.182 (18.2%).

Table 5.4: EXP-C1 triage simulation results across asset criticality tiers.

Asset Criticality Tier	Top-100 KEV: Linear	Top-100 KEV: Nonlinear	Δ KEV (Top-100)	Top-1000 KEV: Linear	Top-1000 KEV: Nonlinear	Top-100 Jaccard Overlap
Tier 1 ($x_4 = 0.25$)	100 / 100	3 / 100	-97	1000 / 1000	315 / 1000	0.005
Tier 2 ($x_4 = 0.50$)	100 / 100	3 / 100	-97	1000 / 1000	315 / 1000	0.005
Tier 3 ($x_4 = 0.75$)	100 / 100	3 / 100	-97	1000 / 1000	315 / 1000	0.005
Tier 4 ($x_4 = 1.00$)	100 / 100	3 / 100	-97	1000 / 1000	315 / 1000	0.005

Investigation of the underlying Parquet export (where unique tier keys `score_lin_tier_k` and `score_nonlin_tier_k` were verified) identified the mathematical root cause:

$$S_{\text{nonlinear}} = x_4 [1 - (1 - x_1)^{1+\alpha x_3} (1 - x_2)^{1+\beta x_3}]$$

When a vulnerability has a CVSS v3.1 base score of 10.0, $x_1 = 1.0$. Consequently, $(1 - x_1) = 0$, causing the entire complement-product term to evaluate to zero regardless of the values of EPSS (x_2) or KEV status (x_3). The score collapses identically to $S_{\text{nonlinear}} = x_4$.

In the 227,694 dataset, exactly **731 CVEs** have CVSS = 10.0. All 731 tie at the exact maximum score x_4 . Among these 731 CVEs, **only 46 (6.3%) are KEV-positive**, while **685 (93.7%) are not listed in KEV as of the dataset freeze date**. Because the experiment script sorts descending scores without a deterministic secondary tie-breaker, the top-100 entries are selected arbitrarily by internal dataset row order. Exactly three KEV vulnerabilities happened to appear in the first 100 positions of that 731-row tie block.

In contrast, the linear formulation:

$$S_{\text{linear}} = 0.25x_1 + 0.25x_2 + 0.25x_3 + 0.25x_4$$

adds +0.25 directly when $x_3 = 1$, directly rewarding KEV membership and favoring KEV-listed vulnerabilities over unlisted CVSS 10.0 vulnerabilities in the ranking, all else being equal. Importantly, the observed 100/100 top-100 KEV capture by the linear formula is specific to this dataset and ranking, and reflects the retrospective inclusion of known KEV catalog membership (x_3) as an explicit additive input feature rather than a mathematical guarantee for every record or an independent prospective prediction. Consequently, the discrepancy between the linear and nonlinear top-100 capture is not evidence that linear weighting provides a superior predictive prioritization policy, but rather an exploratory demonstration of two distinct phenomena: the retrospective dominance of an explicit catalog label in the linear formula, and the severe boundary saturation and tie-breaking vulnerability of the complement-product formulation.

5.5 SHAP feature attribution

Post-hoc SHAP analysis was conducted using TreeExplainer on 2,000 test samples. For EXP-A1, the highest mean absolute SHAP attributions were associated with specific technical terms including `tfidf_unauthorized` (0.34222) and `tfidf_unauthenticated` (0.34216). For EXP-B2, prominent attributions included `tfidf_gain` (0.82117), `CWE-22` (Path Traversal, 0.59967), and `tfidf_critical` (0.54493).

These attributions reflect statistical associations within the fitted tree ensembles and should not be interpreted as evidence of causal exploitability mechanisms.

6. Discussion

The empirical findings highlight several methodological principles for vulnerability prioritization research.

First, the CVSS regression results (EXP-A1) show that text descriptions and structural metadata provide predictive signal for technical severity on the evaluated temporal partition (MAE 0.9721 vs 1.0918). Applying inductive preprocessing confirms that out-of-sample predictive utility is maintained on this partition when test-set vocabulary and category distributions are strictly withheld during training and tuning. However, this finding remains qualified to the evaluated dataset: because the text descriptions originate from a cumulative post-analysis NVD snapshot, the benchmark reflects estimation on archived post-disclosure metadata rather than proven prospective accuracy across repeated historical disclosure intervals.

Second, predicting KEV catalog inclusion without threat intelligence under a temporal split (EXP-B2) is severely constrained by class imbalance (0.3222% prevalence). While XGBoost achieves an average precision of 0.02718 (8.4 times random prevalence), on this test partition, the model’s Precision@500 was 7.2% (36 KEV-positive records among the 500 highest-ranked CVEs). This result indicates limited precision for identifying KEV-listed vulnerabilities under the evaluated data and feature-timing constraints.

Third, the sensitivity comparison between EXP-B2 and EXP-B1 quantifies the risk of retrospective threat-intelligence leakage. In the retrospective sensitivity comparison, adding a static EPSS snapshot that postdates vulnerability disclosure, alongside independent hyperparameter re-tuning, is associated with an increase in average precision from 0.02718 to 0.33578. In an unvetted evaluation, this 12.35-fold increase could easily be mistaken for algorithmic effectiveness. Researchers must strictly ensure that time-varying threat scores are synchronized with the historical prediction timestamp.

Finally, the EXP-C1 analysis demonstrates that summary correlation metrics can conceal critical queue-head failures. Despite a near-perfect Spearman correlation ($\rho = 0.9962$), the nonlinear formula suffered severe top-100 degradation due to CVSS 10.0 saturation and arbitrary tie-breaking. Conversely, the linear formula’s top-100 capture is driven directly by incorporating the KEV label as an input. Prioritization systems must explicitly evaluate boundary cases and implement deterministic tie-breaking.

7. Limitations and Threats to Validity

1. **Cumulative Metadata Snapshot:** The NVD dataset was captured in a single snapshot on July 26, 2026. The repository does not contain historical change logs proving that descriptions, CWE identifiers, and CPE trees were available in their recorded state at disclosure.
2. **Inductive vs. Historical Preprocessing:** While inductive preprocessing prevents test-partition statistical leakage, it does not reconstruct the historical state of the vocabulary as it existed in 2022 or 2024.
3. **Observational Label Censoring:** KEV status reflects catalog inclusion as of July 26, 2026. Vulnerabilities published late in the test period have had less operational exposure time to be observed, exploited, and cataloged.
4. **Retrospective EPSS Snapshot:** EXP-B1 deliberately utilizes a retrospective EPSS snapshot (July 16, 2026) as a negative control; its metrics must not be interpreted as prospective performance.
5. **Score Saturation and Tie Sensitivity:** The nonlinear formula in EXP-C1 saturates at CVSS 10.0, producing 731 ties whose queue order depends on dataset indexing. EXP-C1 is exploratory and should not be used as an operational recommendation.
6. **Absence of Operational Validation:** The study does not incorporate enterprise ticketing, patching velocity, remediation costs, or incident data. It cannot evaluate real-world workload reduction or security outcomes.
7. **Associational Explainability:** SHAP values describe internal model feature importance and do not establish causal vulnerability properties.

8. Reproducibility and Implementation Notes

All experiment scripts, preprocessors, and serialized artifacts are version-controlled in the repository under `scripts/experiments/` and `data/experiments/phase3_corrected/`. Original baseline artifacts are immutably preserved in `data/experiments/phase3_baseline/`.

The software implementation includes 52 passing automated pytest tests across authentication/RBAC, backend API

contracts, batch triage endpoints, ETL data invariants, and leakage-safe preprocessing pipelines. These tests verify software correctness and artifact integrity, but do not eliminate the methodological constraints described above.

9. Conclusion

This paper evaluated CVSS regression, KEV exploitation prediction, and multi-criteria vulnerability triage within the Vulnerability Prioritization & Triage System (VTS). Under a strict inductive preprocessing protocol, XGBoost reduced CVSS regression MAE by approximately 11.0% (from 1.0918 for Ridge to 0.9721) on 81,604 held-out test CVEs. For KEV-membership prediction without EPSS under a temporal split (EXP-B2), XGBoost achieved an average precision (AP) of 0.02718 and Precision@500 of 7.2% on an imbalanced test set (0.3222% prevalence). Supplying a retrospective EPSS snapshot (EXP-B1) resulted in an elevated average precision of 0.33578 and Precision@500 of 26.8%, demonstrating the acute sensitivity of offline vulnerability evaluations to post-disclosure threat telemetry and model retuning.

Crucially, neither the ~11% CVSS error reduction nor the retrospective EPSS performance provides evidence of operational security effectiveness: input fields were not reconstructed to zero-hour disclosure states, and exploratory triage simulations revealed severe boundary saturation and tie-breaking vulnerabilities. These findings underscore the necessity of temporal feature qualification, partition-isolated preprocessing, and rigorous queue-head evaluation. VTS serves as an experimental prototype for identifying these evaluation challenges rather than an operational defense system.

Acknowledgment

The authors would like to thank Prof. Divya Nimbalkar for her guidance and academic support throughout this project. We also acknowledge the Department of Computer Engineering, Vidyalkar Institute of Technology, for providing the academic environment in which this work was undertaken.

Code and Data Availability

The implementation and experimental code for this study are available in the project repository:

- **Repository:** <https://github.com/seucra/vulnerability-prioritization-triage-system>
- **Experimental artifacts:** See the repository’s `data/`, `scripts/`, and relevant experiment documentation, where available.
- **Reproducibility:** The reported results were obtained using the dataset snapshots, temporal partitions, feature configurations, and model settings described in the methodology. Exact reproduction requires access to the corresponding data and experiment artifacts.

The dataset is based on the National Vulnerability Database (NVD), with exploitation labels derived from the CISA Known Exploited Vulnerabilities (KEV) catalog and EPSS data from FIRST. These sources are available at NVD, CISA KEV, and FIRST EPSS.

References

1. National Institute of Standards and Technology, *Measuring the Common Vulnerability Scoring System Base Score Equation*, NIST Interagency/Internal Report 8409, 2022. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/ir/2022/NIST.IR.8409.pdf>
2. FIRST, “EPSS FAQ.” [Online]. Available: <https://www.first.org/epss/faq>
3. FIRST, “Using EPSS.” [Online]. Available: <https://www.first.org/epss/using-epss>
4. Cybersecurity and Infrastructure Security Agency, “Known Exploited Vulnerabilities Catalog.” [Online]. Available: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
5. H. Le, T. Chen, and M. A. Babar, “A Survey on Data-driven Software Vulnerability Assessment and Prioritization,” *ACM Computing Surveys*, vol. 55, no. 5, 2022, doi: 10.1145/3529757.
6. S. M. Lundberg and S.-I. Lee, “A Unified Approach to Interpreting Model Predictions,” in *Advances in Neural Information Processing Systems*, vol. 30, 2017.

Appendix A. Claim qualification checklist

Before submission, confirm that the manuscript preserves these qualifications:

- Describe the split as a **temporal partition of post-analysis NVD records**, not a zero-hour prospective evaluation.
- State clearly that preprocessing follows a two-stage inductive protocol (fitted on training data during tuning, then refitted on train+val before test evaluation).
- Define the KEV target as catalog membership as of the July 26, 2026 dataset freeze date.
- Describe EXP-B1 strictly as a retrospective EPSS-snapshot sensitivity analysis; do not describe its metrics as prospective performance.
- Clarify that baseline-versus-corrected differences reflect both leakage removal and hyperparameter re-selection.
- State that the linear formula in EXP-C1 directly includes the KEV catalog indicator as an input feature and does not independently predict exploitation.
- Keep EXP-C1 exploratory and disclose its CVSS 10.0 saturation defect and row-order sensitivity.
- Do not claim enterprise workload reduction, patching acceleration, or breach prevention.
- Preserve author names (Shams Tabrez Ahmed [Lead Author], Abaan Mhaisker, Om Shelke, Ayush Singasane, Lakshya Walurkar [Co-authors]), institutional affiliation (Department of Computer Engineering, Vidyalkar Institute of Technology, Mumbai), and faculty guidance acknowledgment for Prof. Divya Nimbalkar.

Appendix B. Suggested next experiments

1. Reconstruct historical disclosure-time features using archived NVD Git repositories or the NVD CVE History API to evaluate true zero-hour prospective performance.
2. Align time-indexed EPSS scores to each CVE's exact publication date with a fixed observation window (e.g., EPSS at $t_0 + 30$ days).
3. Evaluate decision-support curves across continuous review budgets ($k \in [100, 5000]$) and assess probability calibration under extreme class imbalance.
4. Redesign the multi-criteria ranking formula to eliminate CVSS 10.0 saturation, enforce deterministic secondary tie-breaking, and benchmark against cost-sensitive triage utility functions.